days.[163] Commenters expressed that these steps often include remediating the security incident directly, conducting a risk assessment and investigation to determine what information may have been affected, obtaining the information needed to make notification to affected individuals, arranging identity protection services for affected individuals, and generating and delivering the notifications to affected individuals, all while simultaneously engaging in extensive communication with and oversight from senior management, the board of directors, and external parties (such as outside counsel, expert consultants, and regulators).[164]

Some commenters also suggested that the proposed timing requirements would lead to covered institutions delivering unnecessary or incomplete notifications to customers, which would have the result of confusing or desensitizing customers to such notifications.[165] Similarly, commenters expressed that requiring a covered institution to notify affected individuals before the covered institution has had time to fully assess an incident could result in incorrect or incomplete conclusions being drawn and disclosed.[166] One commenter suggested, for this reason, that notices would be subject to continuous revision during an ongoing investigation.[167] Accordingly, commenters stated that the Commission should revise the proposal to allow more time for covered institutions to provide notices to affected individuals, asserting that premature,

---

163 For example, one commenter offered the example of a ransomware attack that successfully shuts down systems and requires significant remediation to recover backup systems, as well as rebuilding and redeploying essential systems prior to conducting a forensic investigation to determine the scope of data subject to unauthorized access or use. *See* CAI Comment Letter. According to this commenter, it would be practically impossible to accomplish these tasks within 30 days of becoming aware of a possible issue, as required under the proposed rules.

164 *See*, *e.g.*, CAI Comment Letter, NASDAQ Comment Letter; IAA Comment Letter 1.

165 *See*, *e.g.*, ACLI Comment Letter; AWS Comment Letter, NASDAQ Comment Letter.

166 NASDAQ Comment Letter; AWS Comment Letter.

167 AWS Comment Letter.

incomplete, or frequent notifications would ultimately mislead and confuse customers rather than provide clarity about an incident.[168]

Several commenters suggested alternatives to the proposed timing requirements.[169] For instance, a few commenters urged the Commission to expand the 30-day outside date to 45 or 60 days, stating that this modification would allow more time for a proper investigation and notification process.[170] In addition, a couple of commenters suggested that the rule should not specify a number of days at all.[171] One of these commenters stated that simply requiring a covered institution to notify affected individuals as soon as possible after the conclusion of an investigation, without including an outside date timeframe, would permit appropriate notification in both simple cases—where notification in less than 30 days may be appropriate—and more complex cases—where it may take significantly longer to identify the appropriate notice population and prepare and deliver notifications.[172]

Some commenters suggested that the trigger for notification should be the completion of a reasonable investigation and conclusion of the incident response process following the actual or reasonably likely unauthorized access to or use of sensitive customer information, rather than the proposal's trigger of a covered institution "becoming aware" of a breach of customer information.[173] These commenters stated this alternative would allow covered institutions

---

168 ACLI Comment Letter; AWS Comment Letter, NASDAQ Comment Letter.

169 *See*, *e.g.*, IAA Comment Letter 1; FSI Comment Letter; Cambridge Comment Letter; Federated Comment Letter; SIFMA Comment Letter 2.

170 *See* FSI Comment Letter; Cambridge Comment Letter; IAA Comment Letter 1.

171 Federated Comment Letter; SIFMA Comment Letter 2.

172 SIFMA Comment Letter 2.

173 *See* SIFMA Comment Letter 2; ACLI Comment Letter; *see also* CAI Comment Letter (suggesting that a revised rule could require covered institutions to conduct a prompt investigation of potential incidents to address concerns about lengthy investigations unduly delaying customer notification.).

sufficient time to engage in system and data analysis to determine what data was impacted and what individuals were affected. Moreover, some commenters stated that their suggested alternatives would harmonize the rule's approach to timing with existing data breach requirements and guidance, such as the Banking Agencies' Incident Response Guidance and some current state laws.[174] Lastly, one commenter urged that the 30-day outside timeframe to provide notices should run from the time that the covered institution determines that an incident involved "sensitive customer information," rather than "customer information" as proposed. [175]

After considering comments and alternatives suggested by commenters, we are adopting the final amendments as proposed. We considered the concern raised by commenters that it may be logistically challenging for covered institutions to provide notice to affected individuals within the proposed rule's notification timing requirements, particularly for more complex data breach incidents.[176] We recognize that modifying the timing trigger in the rule to start after a covered institution has completed an investigation that comes to a definitive conclusion about the precise details of the breach, as suggested by some commenters, could avoid over-notification in cases where a covered institution is able to determine that a given individual's customer information ultimately was not affected after a lengthy investigation. We agree with commenters, however, that timeliness is important in the context of a breach of sensitive customer information because delay in notification would impact the ability of affected individuals to take measures to

---

174 *See* FSI Comment Letter; SIFMA Comment Letter 2 (suggesting conforming to Banking Agencies' Incident Response Guidance which does not mandate specific number of days to provide notices); *see also* IAA Comment Letter 1 (stating that "over half of state data breach notification laws do not specify a number of days to report a breach and a majority of those states that do require notification allow for 45-60 days for reporting").

175 IAA Comment Letter 1 (suggesting that referring to "customer information," rather than "sensitive customer information," in this part of the proposed rule was an inadvertent omission).

176 *See, e.g.,* CAI Comment Letter; ACLI Comment Letter.

protect themselves. Accordingly, the final amendments maintain the proposed timing trigger of after the covered institution "becomes aware" that unauthorized access to or use of customer information has occurred or is reasonably likely to have occurred.[177]

In addition, the final amendments adopt the proposed 30-day outside date. We disagree that the rule should not include a specified notification deadline, as such an approach would diminish the goal of providing customers (regardless of state residency) with early and consistent notification of data breaches so that they may take remedial action because many states do not have any specific deadline for sending notices or provide deadlines exceeding 30 days.[178]

We understand that there are a number of steps a covered institution may have to take after becoming aware of a data breach incident to determine if it has met the standard for providing notice. In the context of the final amendments, 30 days should be sufficient to conduct an initial assessment and notify affected individuals. While a covered institution may still be working towards remediating the breach after the 30-day timeframe, the final amendments

---

[177] While this "becoming aware" standard differs from the reporting trigger in the Public Company Cybersecurity Rules (which require public disclosure of public issuer cybersecurity incidents four business days from when an issuer determines that a cybersecurity incident that it has experienced is material), that difference is attributable to the different purposes underlying the rules. The Public Company Cybersecurity Rules were designed to inform investment and voting decisions and to reduce information asymmetry and mispricing in the market, and therefore tie public disclosure to an issuer making a determination that information about an incident would be material, meaning there would be a substantial likelihood that a reasonable shareholder would consider it important in making an investment decision. As we stated in that release, "we reiterate, consistent with the standard set out in the cases addressing materiality in the securities laws, that information is material if 'there is a substantial likelihood that a reasonable shareholder would consider it important' in making an investment decision, or if it would have 'significantly altered the "total mix" of information made available.'" *See* Public Company Cybersecurity Rules. By contrast, the notice provisions under these final rules do not require covered institutions to make a materiality determination, and balance the need for timely notifications with a regime that allows for reasonable investigations to avoid over-notification by allowing covered institutions up to 30 days to conduct a reasonable investigation after becoming aware of an incident. In light of this 30-day window, and the fact that covered institutions are not required to make a materiality determination, there is less need for a trigger based on a determination standard, and greater risk of harm to affected individuals if customer notification were further delayed by requiring that a covered institution come to a determination before triggering the 30-day notification window.

[178] *See infra* section IV.D.1.b(2).

require a covered institution to notify affected customers within the 30-day timeframe so that affected individuals may take measures to protect themselves. The final amendments remove the specific requirement in the proposal that the notice describe what has been done to protect the sensitive customer information from further unauthorized access or use.[179] This change will help address some of the timing and logistical concerns raised by commenters because the process of preparing the requisite notices will be less time intensive, such that, once a covered institution has made its initial assessment of the incident and determined the universe of affected individuals, it should possess the information necessary to provide the requisite notices.

In addition, with regard to the commenter concern that it may be logistically challenging to provide a notice within the rule's timing requirements in cases where a ransomware attack has denied the covered institution access to its systems,[180] that comment does not account for the fact that, under the proposed and final amendments, covered institutions will now be required to have an incident response program that includes policies and procedures to, among other things, assess the nature and scope of any qualifying incidents, identify customer information systems and types of customer information that may have been accessed or used without authorization, and respond to and recover from those incidents.[181] Thus, as proposed, consistent with the final amendments, covered institutions will need to anticipate and prepare for the possibility that they may be denied access to a particular system (such as in the ransomware example offered by one commenter) and have procedures in place for complying with the notice requirements when applicable.

---

179 *See* final rule 248.30(a)(4)(iv); *infra* section II.A.3.e. (discussing in more detail the modification to the notice content requirements).

180 *See* CAI Comment Letter.

181 *See supra* section II.A; final rule 248.30(a).

Consistent with the proposal, the final amendments will require that covered institutions provide notices "as soon as practicable," but not more than 30 days, after becoming aware that unauthorized access to or use of customer information has occurred or is reasonably likely to have occurred. The amount of time that would constitute "as soon as practicable" may vary based on several factors, such as the time required to assess, contain, and control the incident.[182] The requirement to notify affected individuals as soon as practicable but not more than 30 days in the final amendments is consistent with the purposes of the GLBA and reflects the importance of expeditious notification. The amendments are designed to help ensure that customers receive notification in a timely manner. It would be contrary to this policy goal for a covered institution to unduly delay notification to customers, for example by delaying notice until it has definitively concluded that a data breach incident has occurred, because this could result in excessively delayed notifications that could unnecessarily hinder affected customers from engaging their own remedial measures to protect their data. A covered institution should act promptly and must not delay its initial assessment of the available details of the incident as delaying notices could deprive customers of the ability to take prompt action to protect themselves.

The 30-day outside timeframe under both the proposed and final rules begins following an incident involving customer information. This is consistent with the scope of the incident response program, which is required to address unauthorized access to or use of customer information. The outside timeframe does not begin from the time that the covered institution determines that an incident involved "sensitive customer information," as suggested by one

---

[182] For example, an incident of unauthorized access by a single employee to a limited set of sensitive customer information may take only a few days to assess, remediate, and investigate. In those circumstances a covered institution generally should provide notices to affected individuals at the conclusion of those tasks and as soon as the notices have been prepared. *See* Proposing Release at n.133.

commenter.[183] The commenter's suggested modification would likely delay notification as compared to the final rule because covered institutions could take considerable time to determine that an incident involved sensitive customer information before the outside timeframe would begin and this could further delay any potential notice to affected individuals.

(2) National Security and Public Safety Delay

The final amendments will allow covered institutions to delay providing notice if the Attorney General determines that the notice required under the final amendments poses a substantial risk to national security or public safety, and notifies the Commission of such determination in writing, in which case the covered institution may delay such notice for a time period specified by the Attorney General, up to 30 days following the date when such notice was otherwise required to be provided.[184] Previously referred to as the "law enforcement exception" in the proposal, the national security and public safety delay has been expanded to incorporate risks related to public safety in addition to national security. In a modification of the proposal, in which the Attorney General would have informed only the covered institution in cases where this delay is granted, in the final amendments the Attorney General will instead inform the Commission, in writing, if the Attorney General determines that the notice poses a substantial risk to national security or public safety. This modification is designed to ensure that the Commission receives information related to a delay in notice in an efficient and timely manner. We have consulted with the Department of Justice to establish an interagency communication process to allow for the Attorney General's determination to be communicated to the Commission in a timely manner. The Department of Justice will notify the covered institution

---

183 IAA Comment Letter 1.

184 *See* final rule 248.30(a)(4)(iii).

that communication to the Commission has been made so that the covered institution may delay providing the notice.

In another change from the proposal, the notice may be delayed for an additional period of up to 30 days if the Attorney General determines that the notice continues to pose a substantial risk to national security or public safety and notifies the Commission of such determination in writing. In a further change in response to comments, in extraordinary circumstances, notice may be delayed for a final additional period of up to 60 days if the Attorney General determines that notice continues to pose a substantial risk to national security and notifies the Commission of such determination in writing. Beyond the final 60-day delay, if the Attorney General indicates that further delay is necessary, the Commission will consider additional requests for delay and may grant such delay through a Commission exemptive order or other action. By contrast, the proposed rules would have allowed a covered institution to delay notice only for an aggregate period of 30 days following a written request from the Attorney General to the covered institution, upon the expiration of which the covered institution would have been required to provide notice immediately. The modification to the proposed rule is designed to respond to concerns raised by commenters.[185]

One commenter stated that a delay in notifying affected individuals for law enforcement activity may cause harm to customers whose personal information has been exposed.[186] In addition, this commenter asserted that notifying affected individuals would not impede a law enforcement investigation of the data security incident.

---

[185] The final amendments will align more closely with the Public Company Cybersecurity Rules on this point by incorporating a similar scope and timing for its national security and public safety delay.

[186] Better Markets Comment Letter.

Other commenters, however, urged the Commission to expand the proposed law enforcement exception because, in their view, the proposed exception was too narrowly drawn.[187] Several of these commenters expressed concern that requests by local or State police, or even other Federal agencies, would not be sufficient to delay notification under the proposed rule.[188] Some commenters stated concerns about the feasibility and process of reaching out to the Attorney General to request a delay in support of expanding the exception to permit other law enforcement agencies to direct a covered institution to delay a notice.[189] Commenters also expressed particular concern around competing requirements, noting that many state regulations include a more permissive delay and that covered institutions, in an effort to comply with the proposed exception, may be put into the difficult and unnecessary position of being subject to conflicting requirements from the Commission and a state law enforcement entity.[190] Further, commenters articulated that the proposed exception is excessively narrow because it only accommodates law enforcement actions that address concerns that rise to the level of "national security."[191]

In addition to concerns regarding the scope of the proposed law enforcement exception, several commenters opposed the length of time that a covered institution would be permitted to

---

187 *See*, *e.g.*, IAA Comment Letter 1; SIFMA Comment Letter 2; NASDAQ Comment Letter; CAI Comment Letter; FII Comment Letter.

188 *See*, *e.g.*, CAI Comment Letter; ICI Comment Letter 1; FII Comment Letter; SIFMA Comment Letter 2 (suggesting that the proposed law enforcement exception should also contemplate foreign law enforcement and include cooperation with international authorities).

189 *See* ICI Comment Letter; SIFMA Comment Letter 2.

190 *See*, *e.g.*, ICI Comment Letter 1; NASDAQ Comment Letter; FII Comment Letter; IAA Comment Letter 1 (viewing the proposed exception as creating broader security risks for clients and advisers and forcing an adviser to choose between disregarding a law enforcement request or violating the rule).

191 CAI Comment Letter; ICI Comment Letter 1; SIFMA Comment Letter 2.

delay notice under the proposed rule.[192] These commenters suggested that there should be no outside time limitation on the proposed law enforcement exception, asserting that the judgment of any law enforcement agency investigating a breach should be an adequate and respected basis for delaying a regulatory notice regarding such breach. Commenters urged the Commission to expand the scope and timing requirements of the proposed law enforcement exception, expressing that they failed to understand the public purpose that would be served by ignoring the request of a law enforcement agency to delay notification.[193]

In response to commenters' concerns, we have broadened both the scope and timing requirements of the delay in the final amendments. The final amendments will allow covered institutions to delay notice in cases where disclosure would pose a substantial risk to national security or public safety, contingent on a written notification by the Attorney General to the Commission.[194] This provision has been expanded to incorporate risks related to public safety, and not just national security, as proposed. This expansion allows for notice delay in scenarios where there may be significant risk of harm from disclosure; however, there may not be a substantial risk to national security. This modification should make the provision sufficiently expansive to protect against significant risks of harm from disclosure—such as the risk of alerting malicious actors targeting critical infrastructure that their activities have been

---

192 *See*, *e.g.*, IAA Comment Letter 1; ICI Comment Letter 1; NASDAQ Comment Letter; SIFMA Comment Letter 2; CAI Comment Letter.

193 *See*, *e.g.*, IAA Comment Letter 1; NASDAQ Comment Letter; *see also* SIFMA Comment Letter 2 (stating its view that only for a limited number of cases would delay be requested or mandated by other government entities, or court orders, so notification delays would not become routine or be otherwise abused).

194 A covered institution requesting that the Attorney General determine that notification under the rule would pose a substantial risk to national security or public safety does not change the covered institution's obligation to provide notice to affected customers within the timing required under the final amendments. This is because the rule permits a delay only upon the Attorney General making that determination and communicating it to the Commission in writing.